Software Engineering

1. Qualitative Assessment

Qualitative Risk Assessment

- A systematic method of inquiry that focuses characterized by
  - Identifying, interpreting, and explaining the characteristics, meanings, patterns, and relationships present in non-numerical data
  - Relying on conceptual categorization, thematic interpretation, or structural examination rather than numerical measurement
  - Generating rich, contextualized understanding of phenomena by analyzing textual, visual, auditory, or observational data through iterative, transparent, and methodologically justified procedures
- Qualitative analysis is a discipline-neutral methodology

Qualitative Analysis

- Characteristics
  - The nature of the data it operates on is
    - *Non-quantified: For example: text, images, behaviors, symbols, speech*
    - *Complex and context-dependent*
    - *Open to multiple levels of meaning : For example literal, subjective or cultural*
  - An analytical process involving
    - *Systematic coding or classification of data into meaningful categories*
    - *Identification of patterns, themes, or constructs*
    - *Interpretive reasoning grounded in the data*
    - *Iterative refinement of categories and interpretations*
    - *Explicit methodological transparency to ensure rigor and credibility.*

Qualitative Risk Assessment

- Uses non-numerical scales to rate:
  - Likelihood of a risk occurring
  - Impact the risk would have
  - Overall risk priority
- It relies on information gathered from
  - Subject matter expertise
  - Organizational experience
  - Interviews and workshops
  - Trend data
  - Stakeholder perceptions
- While not mathematically precise, qualitative assessment accelerates decision making and supports triage of risks for deeper analysis

Ordinal Data

- A type of measurement scale
  - Used in qualitative research where data are categorized and ranked
  - But the distances between the ranks are not meaningful
- Key characteristics
  - Categories are ordered (lowest to highest, least to most, etc.)
  - No fixed or equal intervals between categories
  - No meaningful zero point
  - Labels are often words, not numbers, though numbers may be used for coding

Ordinal Data

- Ordinal scales are useful when researchers want to
  - Capture attitudes, preferences, or perceptions
  - Measure levels of a qualitative attribute
  - Convert open-ended or textual information into analyzable ranked categories
  - Combine qualitative insight with basic quantitative analysis
- Ordinal scales bridge the gap between purely qualitative data (e.g., interview text) and measurable patterns

Ordinal Data

- Appropriate statistical treatment
  - Appropriate methods
    - *Median, mode*
    - *Percentiles*
    - *Non-parametric tests (Mann–Whitney U, Kruskal–Wallis)*
    - *Rank correlation (Spearman’s rho, Kendall’s tau)*
  - Not appropriate
    - *Mean*
    - *Standard deviation*
    - *Parametric tests based on equal intervals*

Ordinal Data

- Advantages of ordinal scales
  - Easy for respondents to understand
  - Provides nuanced insight beyond simple categories
  - Allows ordering of qualitative traits
  - Compatible with both qualitative interpretation and quantitative coding
- Limitations of ordinal scales
  - Cannot interpret the magnitude of differences
  - Statistical options are more limited
  - Results may be sensitive to wording or cultural interpretation
  - Ambiguity if categories are unevenly spaced psychologically

Qualitative Analysis

- Reasons to use qualitative assessment
  - Fast and cost-effective
    - *No need for complex models or specialized data*
  - Works well with incomplete data
    - *Ideal when assessing emerging risks or new projects*
  - Engages stakeholders
    - *Brings in expert knowledge and perspectives that numbers alone cannot reveal*
  - Prioritization support
    - *Gives organizations a simple, consistent way to rank risks.*

Common Qualitative Scales

- Likelihood Scale Example

Rating	Description
1 – Rare	May occur only under exceptional circumstances.
2 – Unlikely	Could occur but not expected in normal operations.
3 – Possible	Might occur at some time.
4 – Likely	Will probably occur in most circumstances.
5 – Almost Certain	Expected to occur frequently.

Common Qualitative Scales

- Impact Scale Example

Rating	Description
1 – Negligible	Minimal damage or disruption.
2 – Minor	Short-term disruption; easily recoverable.
3 – Moderate	Noticeable disruption; requires recovery effort.
4 – Major	Significant business process or financial impact.
5 – Severe/Catastrophic	Long-term damage, regulatory failure, or major loss.

Expert Opinion

- Experts often have deep practical knowledge but may lack precise quantifiable data
- SME’s structured insights help
  - Identify risks not visible in metrics
  - Validate assumptions
  - Provide scenario-based insights (“What would happen if…?”)
  - Add context around process weaknesses, operational realities, or threat behaviors

Expert Opinion

- Methods for gathering expert opinion
  - Interviews: One-on-one sessions with SMEs
  - Workshops: Facilitated group discussions
  - Delphi Technique: Anonymous rounds of feedback until consensus is reached
  - SME Scoring: Experts independently score likelihood and impact
- Differences in opinion can be due to
  - Different experiences with the similar process or risk or events
  - Different roles and perspectives taken by their professions
  - Access to different data across industries and organizations
  - Different methods of analysis and interpretation of the same data
  - Assigning different levels of significance to different parts of the data

Surveys and Questionnaires

- Gather insights across broader groups
  - Both within the organization and externally (user opinions for example)
  - Particularly useful in large or distributed teams
  - Provide a scalable way to capture perceptions of risk, operational concerns, and confidence in existing controls
  - However, survey often reflect perceived risk rather than actual risk
- Allow for a larger data set of opinions
  - Can be used to identify trends and clusters of opinions and analyses
  - Allow for factor analysis
    - *For example: perception of the risk posed by AI tools by different operational groups*
    - *For example: correlation between two different risks – seem by experts as being connected*

Problems With Surveys

- Typical issues that can skew survey results
  - Low response rates can make findings unrepresentative
  - Self-selection bias: only highly concerned or highly disengaged people respond
  - Ambiguous wording leads to inconsistent interpretations
    - *For example: “system downtime” may mean hours to some, minutes to others*
  - Leading or risk-loaded questions can make the replies unreliable
  - Reliance on ordinal scales may reduce complex issues to oversimplified answers
  - Survey results reflect beliefs, not technical evidence
    - *Skews data to show perceived risk and not real risk*
  - Lack of context may cause respondents to guess rather than answer confidently
  - People often answer carelessly without thinking about their answer
    - *For example: They just want to be done with the chore of answering the survey*
    - *For example: nay saying and yea saying behaviors*

Benefits Of Surveys

- Surveys can provide strong value by
  - Identifying trends and perception shifts over time
  - Comparing confidence levels across teams or departments
  - Highlighting areas where technical teams may need to communicate better
  - Building a heat map of perceived risk
  - Supporting prioritization for deeper, evidence-based assessments
- Survey blind spots
  - Surveys should be based on prior interviews or data analysis
  - This identifies the questions that should be asked
  - Should include a section asking for feedback on potential blind spots
    - *“Is there anything that in your opinion should have been asked about in this survey?”*

Historical Trends

- Qualitative assessment can be enriched by identifying historical patterns in data from
  - Incident logs
  - Ticketing system data (e.g., ServiceNow, Jira)
  - Security event trends
  - Audit findings
  - Vendor performance issues
  - Previous project retrospectives
  - Root cause analyses
- Historical trends provide:
  - Evidence for likelihood estimation
  - Context for impact assessment
  - Understanding of seasonal or recurring risks
  - Identification of chronic weak controls

Cognitive Biases

- The use of historical and comparative data can identify cognitive biases that can occur in interviews and group data collection
- Anchoring bias
  - The tendency to rely too heavily on the first piece of information presented (the “anchor”)
    - For example: if the interviewer mentions “low likelihood events,” the SME may unintentionally frame all responses around low likelihood even when high-impact events exist
  - Impact
    - Skews likelihood ratings
    - Narrows thinking
  - Mitigation
    - Avoid suggesting ranges before SME answers
    - Ask open-ended questions first

Cognitive Biases

- Availability heuristic
  - Judging risks based on how easily examples come to mind, often driven by recent or memorable events
    - For example: an SME recently experienced a security incident and may overestimate its frequency or importance
  - Impact
    - Over-weighting recent or dramatic events
    - Under-weighting long-standing but less visible risks
  - Mitigation
    - Ask SMEs to reference data, not just memory
    - Use structured prompts: “Are there less visible risks we might be missing?”

Cognitive Biases

- Confirmation bias
  - Seeking or interpreting information that confirms existing beliefs or opinions
    - For example: if an SME believes a control is effective, they may downplay incidents or evidence suggesting weaknesses
  - Impact
    - Inflated confidence in existing controls
    - Rejection of contradictory information
  - Mitigation
    - Ask on-purpose disconfirming questions:
    - “Can you think of situations where this control might fail?”

Cognitive Biases

- Overconfidence bias
  - Overestimating one's knowledge, memory, or accuracy of judgment
    - For example: an SME claims "that process never fails" without data to support the statement
  - Impact
    - Underestimating likelihood
    - False sense of control maturity
  - Mitigation
    - Encourage approximate ranges rather than absolutes
    - Ask for examples, evidence, or exceptions

Cognitive Biases

- Status quo bias
  - A preference for the current state of affairs and reluctance to acknowledge problems
    - For example: an SME may deny risks in a long-standing process simply because “it’s always been done this way”
  - Impact
    - Blind spots in legacy processes
    - Failure to recognize systemic risks
  - Mitigation
    - Ask what changes or failures would look like
    - Use scenario-based probing

Cognitive Biases

- Social desirability bias
  - Respondents tend to give answers they believe will be viewed favorably
    - For example: an SME may underreport known process weaknesses out of fear of blame or reputational impact
  - Impact
    - Hidden failure points
    - Overstated maturity
  - Mitigation
    - Emphasize confidentiality and non-attribution
    - Use neutral, non-judgmental question wording

Cognitive Biases

- Normalcy bias
  - Assuming future operations will resemble past operations and underestimating rare but high-impact risks
    - For example: an SME dismisses disaster scenarios because “we’ve never had that happen”
  - Impact
    - Underestimation of catastrophic but plausible risks
  - Mitigation
    - Use structured hypothetical questions (“What if…?”)
    - Provide external examples from similar organizations

Cognitive Biases

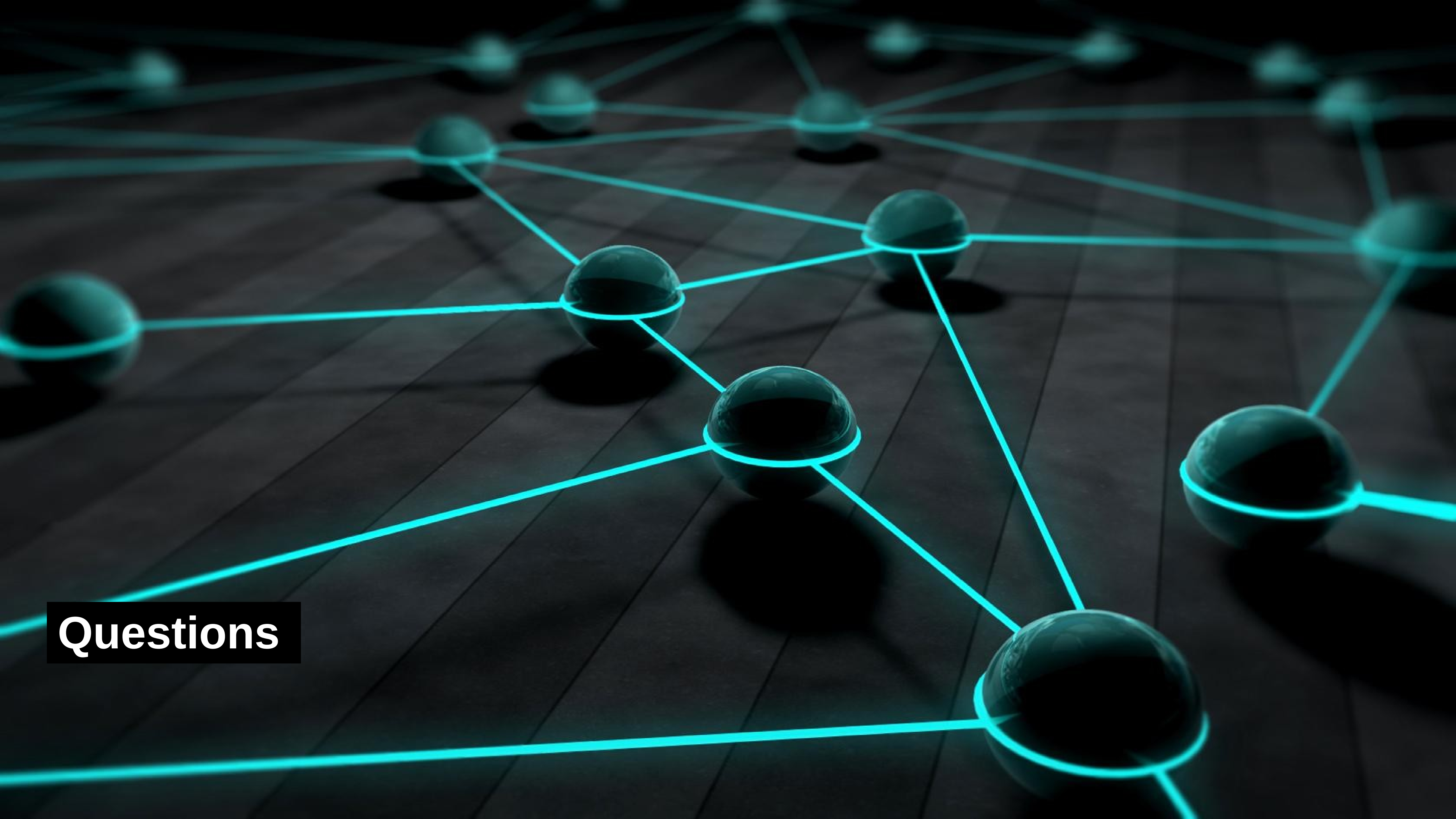
- Group think
  - The desire for group harmony leads participants to avoid expressing dissenting views
    - For example: in a group risk workshop, one dominant SME sets the tone and others follow.
  - Impact
    - Suppressed minority opinions
    - Loss of nuanced or conflicting evidence
  - Mitigation
    - Gather individual ratings first, then discuss
    - Use anonymous voting tools

Cognitive Biases

- Recency bias
  - Recent events are judged as more significant than earlier events
    - For example: a minor incident last week overshadows more important but older risks
  - Impact
    - Inflated ratings for recent issues
    - Neglect of long-term systemic risks
  - Mitigation
    - Ask SMEs to think across multiple timeframes (3 months, 1 year, 3 years)

Qualitative Assessment Process

- Typical process
  - Step 1: collect inputs
    - Interview SMEs about operational risks
    - Review historical incident reports
    - Conduct surveys with frontline staff
  - Step 2: use a standard scale
    - Rate each risk on a 1–5 scale for likelihood and impact
  - Step 3: plot on the qualitative risk matrix
    - Example: A risk with 4 (Likely) and 5 (Severe) goes in the Red Zone
  - Step 4: prioritize
    - High/high → immediate mitigation
    - Medium/low → monitor
    - Low/low → accept



Questions